

OAuth 2.0

- **authorization framework** that lets **third-party apps** access a **user's data without** ever seeing the **user's password**.

1 You click “**Sign in with Google**”

2 Google talks directly to you

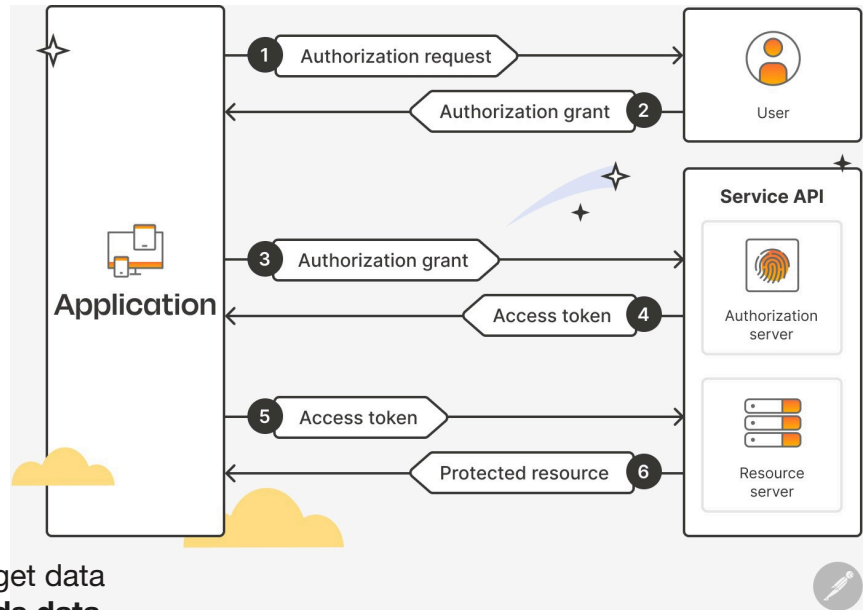
- You enter your gmail & password
- Google asks: “**Do you allow this app to access your email & name?**”
- You click Allow

3 Google sends one **temporary code** to the app

4 App backend exchanges the **code** for a **token**

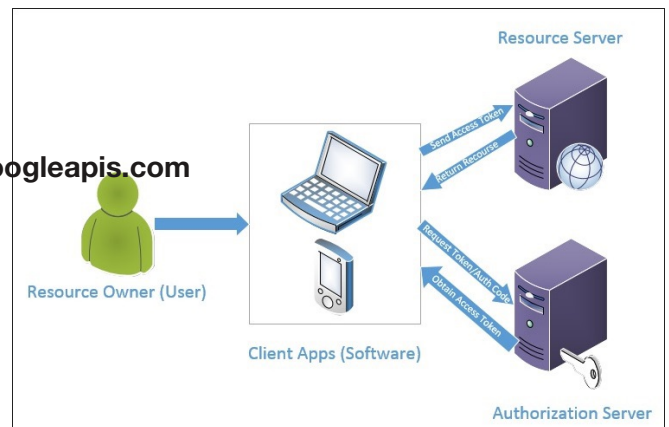
- Google responds with **access token** & refresh token (optional)

5 App uses the access token to get data
Google **verifies the token** → **sends data**.



🔑 Authorization Server (Google)

- examples: **accounts.google.com**, **oauth2.googleapis.com**
- Shows Google login page
- Authenticates the user
- Shows consent screen
- Issues authorization code
- Exchanges code → tokens
- This server implements **OAuth 2.0**



🏠 Resource Server (Google)

- examples: **www.googleapis.com**
- Hosts user data (profile, email, Drive, Calendar, etc.)
- Validates access token
- Returns protected data

